# 实验工作 4
# 口令审计、数据泄露分析与数字卫生

口令管理器 · 泄露排查 · 双因素认证 · 社交隐私


| | |
|---|---|
| 姓　名 | Zhang San |
| 学　号 (IDU) | 12345678 |
| Variant | 1 |
| 日　期 | 2026-10-19 |

## 1. 工作目的

通过一次完整的个人账号安全自查，理解「弱口令 + 复用」为什么是最常见的入侵入口， 掌握口令管理器、泄露查询与双因素认证（2FA）的正确用法，并据此形成可执行的数字卫生规则。

## 2. 口令管理器

使用 **Bitwarden**（免费版）建立密码库。主口令按「四个随机词 + 数字 + 符号」构造，长度 20 位以上，只存在于记忆中，不写入任何文件、不与其他站点复用。库内为每个账号保存独立的随机口令， 并开启 Bitwarden 自身的 2FA。

> 截图待插入：`screenshots/01-bitwarden-setup.png` 、 `02-vault.png` （含打码）

图 1　密码库初始化与主界面（敏感字段已打码）

## 3. 现有口令审计

| 账号类别 | 长度 | 字符种类 | 结论 |
| --- | --- | --- | --- |
| 邮箱 | 8–10 | 小写 + 数字 | 弱：可离线爆破，且与其他站点复用 |
| 社交（VK / Telegram） | 10–12 | 大小写 + 数字 | 中：无符号、曾出现在泄露库 |
| 学校/教务系统 | 8 | 纯数字 | 极弱：字典 + 规则即可命中 |
| 购物/支付 | 12 | 大小写 + 数字 + 符号 | 尚可，但仍复用 |
| 开发平台（GitHub 等） | 14 | 随机 | 强：由管理器生成 |

上述为自查示例，提交前请替换为你自己的真实评估结果。

## 4. 数据泄露检查

在 **haveibeenpwned.com** 只输入邮箱地址（不输入任何口令），查询结果：

- （待填：命中数量与名称）
- 泄露内容：（待填：被泄露的数据类别）
- 处置：对命中站点立即改密、开启 2FA，并检查是否有同一口令在别处复用。

> 截图待插入：`screenshots/03-hibp.png`

图 2　泄露查询结果（仅展示邮箱与命中条目）

## 5. 双因素认证

为 配置了基于 TOTP 的 2FA：服务器与验证器共享种子，每 30 秒生成一次性 6 位码。 即使口令在泄露中暴露，攻击者没有第二因素也无法登录；同时把恢复码离线保存，避免设备丢失后被锁死。

> 截图待插入：`screenshots/05-2fa.png`

图 3　2FA 开启成功与验证器中的条目

## 6. 社交账号公开信息审计

用无痕窗口查看自己的公开主页，陌生可见的信息包括：真实姓名、头像、城市、就读学校、生日（部分可见）、 好友列表、以及带地理位置的动态。这些信息足以支撑一次精准的钓鱼或社工攻击（例如冒充学校教务处发送「补考通知」）。

> 截图待插入：`screenshots/06-social-audit.png`

图 4　未登录状态下的公开信息

## 7. 数字卫生规则（5–7 条）

1. 所有账号使用由口令管理器生成的独立随机口令，绝不复用；只需要记住一个强主口令。
2. 凡是支持 2FA 的账号一律开启，优先 TOTP 而非短信；恢复码离线保存。
3. 每 6 个月检查一次社交账号的隐私设置与公开可见字段，关闭「通过手机号/邮箱被找到」。
4. 不在任何第三方网站输入口令；泄露查询只提交邮箱。
5. 浏览器与系统保持自动更新，重要账号单独使用一个浏览器配置文件。
6. 收到带链接的「紧急通知」先通过官方渠道二次确认，不在邮件/私信里点登录链接。
7. 每年至少一次导出并核对口令库、清理不再使用的账号。

## 8. 简答

**哪些口令是弱的?** 长度不足 12 位、字符种类单一、且与其他站点复用的口令；本次自查中教务系统与邮箱口令属于此类， 后者还出现在公开泄露库中。

**什么是 2FA?** 在「你知道的东西（口令）」之外再要求「你拥有的东西（TOTP 设备、硬件密钥）」或「你本身的特征」， 即使口令泄露，攻击者仍缺少第二因素。TOTP 基于共享密钥与当前时间计算 6 位码，离线可用、不依赖短信网络。

## 9. 结论

个人账号失守通常不是因为「被高级黑客盯上」，而是弱口令复用 + 已泄露凭据被撞库。口令管理器把「记住很多强口令」 变成「记住一个强口令」，2FA 再把「口令泄露」与「账号失守」解耦。数字卫生的本质是把这些动作固化成习惯和周期检查。